Relatório de Auditoria de Segurança

Reserva de Salas (gerado/)

Data: 2026-10-23
Escopo: FastAPI + SQLite + UI estática. Metodologia: 5 categorias (skill revisao-seguranca).

Resumo executivo

Severidade	Qtd
Crítica	0
Alta	0
Média	1
Baixa	1
Informativa	2

Achados (amostra verificada)

Severidade	Local	Descrição
Média	static/index.html:72-74	XSS via innerHTML na agenda (título da reserva)
Baixa	app/main.py:144-163	Cancelamento por ID sem auth
Informativa	app/main.py	API aberta (PRD sem login)
Informativa	app/main.py:64-76	POST /api/salas sem restrição

Pontos fortes

SQL parametrizado; validação Pydantic; sem segredos no repositório; regras em business.py.

Recomendações P1

Eliminar innerHTML na agenda ou sanitizar entradas da API na UI.